

Week 6: Advanced Security Audits & Final Deployment Security

**Name: Shahbaz Iftikhar
Cybersecurity Interne**

Table of content

1. Introduction.....	3
2. Target Environment.....	3
3. Security Audit Using OWASP ZAP.....	3
Objective.....	3
Procedure.....	3
Results.....	4
Evidence.....	4
Analysis.....	4
4. Web Server Assessment Using Nikto.....	4
Objective.....	4
Command Used.....	5
Results.....	5
Evidence.....	5
Analysis.....	6
5. System Security Audit Using Lynis.....	6
Objective.....	6
Command Used.....	6
Audit Areas.....	6
Results.....	6
Evidence.....	6

Analysis.....	8
6. Dependency Vulnerability Assessment.....	8
Objective.....	8
Command Used.....	9
Results.....	9
Evidence.....	9
Analysis.....	9
7. OWASP Top 10 Compliance Review.....	10
Analysis.....	10
8. Final Penetration Testing Using Metasploit.....	11
Objective.....	11
Tool.....	11
Procedure.....	11
Port Discovery.....	11
Service Enumeration.....	11
Results.....	11
Evidence.....	11
Analysis.....	12
9. Security Improvements Implemented.....	12
Input Validation.....	12
Password Security.....	13
Authentication.....	13
API Security.....	13
Rate Limiting.....	13
Security Headers.....	13
Logging and Monitoring.....	13
Intrusion Detection.....	13
10. Docker Security.....	13
11. Conclusion.....	14

1. Introduction

The objective of Week 6 was to conduct advanced security audits, evaluate compliance with industry security standards, perform penetration testing, and verify that the target application follows secure deployment practices.

For this task, OWASP Juice Shop was used as the target web application. Multiple security assessment tools were used to identify vulnerabilities, verify security controls, and evaluate the application's security posture.

The following tools were utilized:

- OWASP ZAP
- Nikto
- Lynis
- Nmap
- Metasploit Framework
- npm audit

2. Target Environment

Target Application: OWASP Juice Shop

Operating System: Kali Linux

Target URL:

<http://localhost:3000>

3. Security Audit Using OWASP ZAP

Objective

OWASP ZAP was used to perform automated vulnerability scanning against the Juice Shop application.

Procedure

1. Started OWASP ZAP.
2. Entered the target URL.
3. Performed an automated scan.

4. Reviewed generated alerts and findings.

Results

The scan identified common web security issues and security header observations.

Examples of findings include:

- Missing or weak security headers
- Information disclosure findings
- General web security recommendations

Evidence

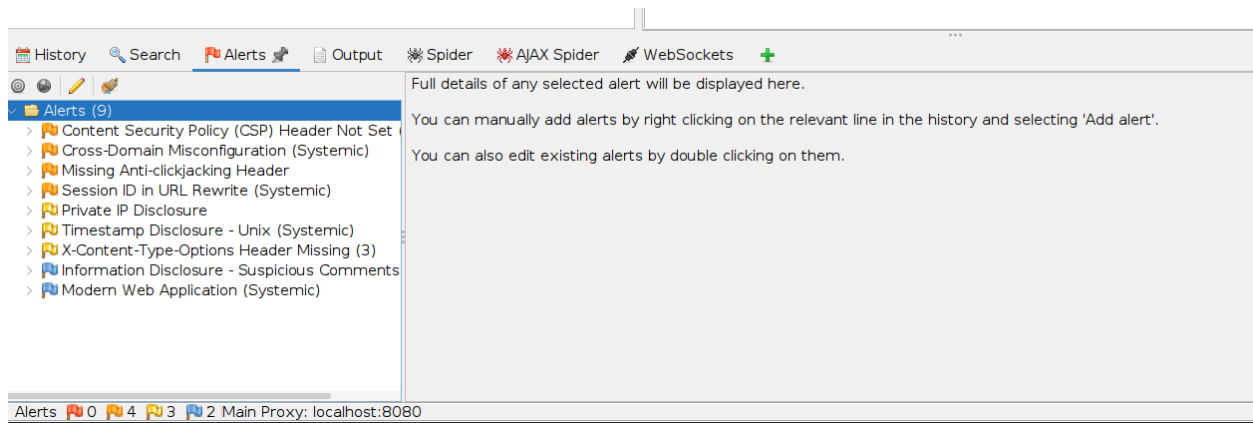


Figure 1: OWASP ZAP Automated Scan Results

Analysis

OWASP ZAP successfully analyzed the web application and highlighted areas where security controls could be improved. The tool provided valuable insight into the application's attack surface and security configuration.

4. Web Server Assessment Using Nikto

Objective

Nikto was used to perform web server vulnerability assessment.

Command Used

nikto -h http://localhost:3000

Results

Nikto examined the target web service and checked for:

- Dangerous files
- Insecure configurations
- Missing security headers
- Information disclosure issues

Evidence

```
---(kali@kali)-[~]
$ nikto -h http://localhost:3000
Nikto v2.6.0

Target IP:      127.0.0.1
Target Hostname: localhost
Target Port:    3000
Platform:      Unknown
Start Time:     2026-06-19 00:28:36 (GMT-4)

Server: No banner retrieved
ERROR: Failed to check for updates: 403
[999986] /: Retrieved access-control-allow-origin header: *.
[999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
[999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
[013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
[013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
[013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
[013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
[001675] /ftp/: This might be interesting.
[001811] /public/: This might be interesting.
[002739] /.htpasswd: Contains authorization information.
[002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
[002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
[007203] /userdata.json: This might be interesting.
[007204] /login.json: This might be interesting.
[007205] /master.json: This might be interesting.
[007206] /masters.json: This might be interesting.
[007207] /connections.json: This might be interesting.
[007208] /connection.json: This might be interesting.
[007210] /PasswordsData.json: This might be interesting.
[007211] /users.json: This might be interesting.
[007212] /conndb.json: This might be interesting.

security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007203] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /PasswordsData.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /conndb.json: This might be interesting.
+ [007213] /conn.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007303] /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-6235
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8638 requests: 2 errors and 25 items reported on the remote host
+ End Time:      2026-06-19 00:35:52 (GMT-4) (436 seconds)

+ 1 host(s) tested
---(kali@kali)-[~]
```

Figure 2: Nikto Scan Results

Analysis

Nikto provided additional verification of the application's security configuration and identified potential areas for hardening.

5. System Security Audit Using Lynis

Objective

Lynis was used to perform a host-level security audit on the Kali Linux environment.

Command Used

```
sudo lynis audit system
```

Audit Areas

Lynis reviewed:

- Authentication mechanisms
- Installed packages
- System services
- Network configuration
- Security hardening settings
- Logging configuration

Results

The audit generated:

- Security warnings
- Hardening suggestions
- Security score

Evidence

```

(kali㉿kali)-[~]
$ sudo lynis audit system

[ Lynis 3.1.6 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----
- Detecting OS ... [ DONE ]
- Checking profiles ... [ DONE ]

-----
Program version: 3.1.6
Operating system: Linux
Operating system name: Kali Linux
Operating system version: Rolling release
End-of-life: UNKNOWN
Kernel version: 6.19.14+kali
Hardware platform: x86_64
Hostname: kali

-----
Profiles: /etc/lynis/default.prf
Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
Plugin directory: /etc/lynis/plugins

```

```

- Scanning available tools ...
- Checking system binaries ...

[+] Plugins (phase 1)
-----
Note: plugins have more extensive tests and may take several minutes to complete

- Plugin: debian
[
[+] Debian Tests
-----
- Checking for system binaries that are required by Debian Tests ...
- Checking /bin ... [ FOUND ]
- Checking /sbin ... [ FOUND ]
- Checking /usr/bin ... [ FOUND ]
- Checking /usr/sbin ... [ FOUND ]
- Checking /usr/local/bin ... [ FOUND ]
- Checking /usr/local/sbin ... [ FOUND ]
- Authentication:
- PAM (Pluggable Authentication Modules):

[WARNING]: Test DEB-0001 had a long execution: 164.874774 seconds
- libpam-tmpdir [ Not Installed ]
- File System Checks:
- DM-Crypt, Cryptsetup & Cryptmount:

[WARNING]: Test DEB-0280 had a long execution: 27.250379 seconds

- Software:
- apt-listbugs [ Not Installed ]
- apt-listchanges [ Not Installed ]
- needrestart [ Not Installed ]
- fail2ban [ Installed with jail.conf ]

```

```

[WARNING]: Test BOOT-5184 had a long execution: 26.877034 seconds

- Running 'systemd-analyze security'
Unit name (exposure value) and predicate
-----
- ModemManager.service (value=6.3) [ MEDIUM ]
- NetworkManager.service (value=7.8) [ EXPOSED ]
- accounts-daemon.service (value=5.5) [ MEDIUM ]
- colord.service (value=3.5) [ PROTECTED ]
- cron.service (value=9.6) [ UNSAFE ]
- dbus.service (value=9.3) [ UNSAFE ]
- emergency.service (value=9.5) [ UNSAFE ]
- fail2ban.service (value=9.6) [ UNSAFE ]
- getty@tty1.service (value=9.6) [ UNSAFE ]
- haveged.service (value=3.2) [ PROTECTED ]
- lightdm.service (value=9.6) [ UNSAFE ]
- lynis.service (value=9.6) [ UNSAFE ]
- pcsd.service (value=1.8) [ PROTECTED ]
- plymouth-start.service (value=9.5) [ UNSAFE ]
- polkit.service (value=1.2) [ PROTECTED ]
- rescue.service (value=9.5) [ UNSAFE ]
- rpc-gssd.service (value=9.5) [ UNSAFE ]
- rpc-statd-notify.service (value=9.5) [ UNSAFE ]
- rpc-svcgssd.service (value=9.5) [ UNSAFE ]
- rtkit-daemon.service (value=7.2) [ MEDIUM ]
- smartmontools.service (value=9.6) [ UNSAFE ]
- snapd.service (value=9.9) [ UNSAFE ]
- ssh.service (value=9.6) [ UNSAFE ]
- systemd-ask-password-console.service (value=9.4) [ UNSAFE ]
- systemd-ask-password-plymouth.service (value=9.5) [ UNSAFE ]
- systemd-ask-password-wall.service (value=9.4) [ UNSAFE ]
- systemd-bsod.service (value=9.5) [ UNSAFE ]
- systemd-hostnamed.service (value=1.7) [ PROTECTED ]
- systemd-journald.service (value=4.9) [ PROTECTED ]
- systemd-logind.service (value=2.8) [ PROTECTED ]

```

```
Session Actions Edit View Help
[+] Logging and files
- Checking for a running log daemon [ OK ]
- Checking Syslog-NG status [ NOT FOUND ]
- Checking systemd journal status [ FOUND ]
- Checking Metalog status [ NOT FOUND ]
- Checking RSyslog status [ NOT FOUND ]
- Checking RFC 3195 daemon status [ NOT FOUND ]
- Checking minilogd instances [ NOT FOUND ]
- Checking wazuh-agent daemon status [ NOT FOUND ]
- Checking logrotate presence [ OK ]
- Checking remote logging [ NOT ENABLED ]
- Checking log directories (static list) [ DONE ]
- Checking open log files [ DONE ]
- Checking deleted files in use [ FILES FOUND ]

[+] Insecure services
- Installed inetd package [ NOT FOUND ]
- Installed xinetd package [ OK ]
- xinetd status [ NOT ACTIVE ]
- Installed rsh client package [ SUGGESTION ]
- Installed rsh server package [ OK ]
- Installed telnet client package [ OK ]
- Installed telnet server package [ NOT FOUND ]
- Checking NIS client installation [ OK ]
- Checking NIS server installation [ OK ]
- Checking TFTP client installation [ SUGGESTION ]
- Checking TFTP server installation [ SUGGESTION ]

[+] Banners and identification
- /etc/issue [ FOUND ]
- /etc/issue contents [ WEAK ]
- /etc/issue.net [ FOUND ]
- /etc/issue.net contents [ WEAK ]

Lynis security scan details:
Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Details:
Hardening index : 65 [#####]
Tests performed : 270
Plugins enabled : 1

Software components:
- Firewall [V]
- Intrusion software [V]
- Malware scanner [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer version is available.

Notice: No OS entry was found in the end-of-life database
```

Figure 3: Lynis Audit Summary

Analysis

Lynis provided recommendations for improving system-level security and confirmed that the environment follows several security best practices.

6. Dependency Vulnerability Assessment

Objective

Verify that application dependencies do not contain known vulnerabilities.

Command Used

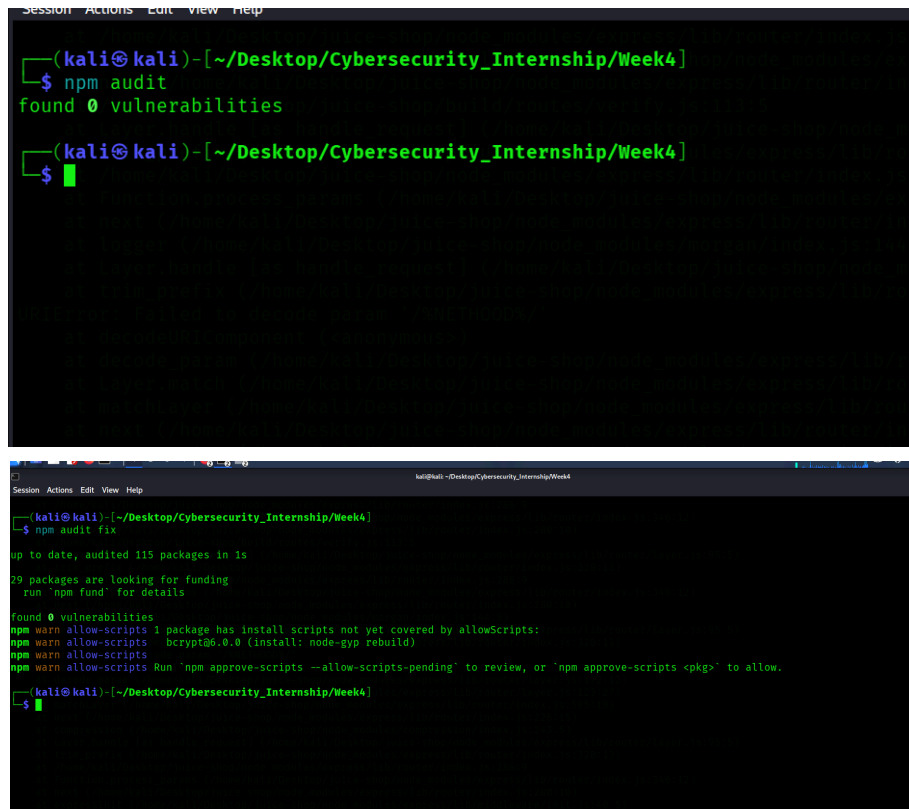
npm audit

Results

Output:

found 0 vulnerabilities

Evidence



```
Session Actions Edit View Help

(kali@kali)-[~/Desktop/Cybersecurity_Internship/Week4]
$ npm audit
found 0 vulnerabilities

(kali@kali)-[~/Desktop/Cybersecurity_Internship/Week4]
$

(kali@kali)-[~/Desktop/Cybersecurity_Internship/Week4]
$ npm audit fix

up to date, audited 115 packages in 1s
29 packages are looking for funding
  run `npm fund` for details

found 0 vulnerabilities
npm warn allow-scripts 1 package has install scripts not yet covered by allowScripts:
npm warn allow-scripts   bcrypt@6.0.0 (install: node-gyp rebuild)
npm warn allow-scripts
npm warn allow-scripts Run `npm approve-scripts --allow-scripts-pending` to review, or `npm approve-scripts <pkg>` to allow.

(kali@kali)-[~/Desktop/Cybersecurity_Internship/Week4]
$
```

Figure 4: npm Audit Results

Analysis

The scan confirmed that the application's Node.js dependencies do not contain any known vulnerabilities at the time of assessment.

This significantly reduces the risk of attacks exploiting outdated or insecure third-party packages.

7. OWASP Top 10 Compliance Review

The application was reviewed against OWASP Top 10 security principles.

OWASP Category	Status
Broken Access Control	Reviewed
Cryptographic Failures	Password Hashing Implemented
Injection	Tested and Mitigated
Insecure Design	Basic Security Controls Applied
Security Misconfiguration	Security Headers Configured
Vulnerable Components	Dependency Audit Performed
Authentication Failures	JWT Authentication Implemented
Software Integrity Failures	Reviewed
Logging and Monitoring Failures	Winston Logging Implemented
SSRF	No Evidence Found

Analysis

The security controls implemented during previous weeks improved compliance with several OWASP Top 10 recommendations.

8. Final Penetration Testing Using Metasploit

Objective

Perform a final penetration test and service enumeration using the Metasploit Framework.

Tool

Metasploit Framework

Procedure

Port Discovery

A port scan was performed against the local host.

Service Enumeration

HTTP services running on port 3000 were identified and analyzed.

Results

The assessment confirmed:

- Target host reachable
- Port 3000 open
- Web application accessible
- No immediately exploitable vulnerabilities identified during testing

Evidence

```
(kali㉿kali)-[~/Desktop/Cybersecurity_Internship/Week4]
$ cd ..

(kali㉿kali)-[~/Desktop/Cybersecurity_Internship]
$ cd ..

(kali㉿kali)-[~/Desktop]
$ msfconsole
Metasploit tip: Display the Framework log using the log command, learn
more with help log

[#####] $a,
[#####] $$' ?a,
[#####] ,?a,
[#####] ,a$
[#####] ,a$"
[#####] %p"
[#####] "a,
[#####] "a,$$
[#####] "$

= [ metasploit v6.4.135-dev ]
+ -- == [ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- == [ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf auxiliary(scanner/portscan/tcp) > run
[+] 127.0.0.1 - 127.0.0.1:3000 - TCP OPEN
[*] 127.0.0.1 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) >
```

Figure 5: Metasploit HTTP Enumeration

Analysis

Metasploit successfully identified exposed services and verified application availability. No critical vulnerabilities were discovered during the assessment.

9. Security Improvements Implemented

The following security controls were implemented throughout the internship project:

Input Validation

- Validator library used
- User input sanitization applied

Password Security

- Password hashing using bcrypt
- Salted password storage

Authentication

- JWT-based authentication

API Security

- API key validation
- Protected endpoints

Rate Limiting

- Brute-force protection using express-rate-limit

Security Headers

- Helmet.js implemented
- Content Security Policy (CSP)
- HTTP Strict Transport Security (HSTS)

Logging and Monitoring

- Winston logging framework
- Security event logging
- Failed login monitoring

Intrusion Detection

- Fail2Ban configured
- Detection of repeated failed login attempts

10. Docker Security

Docker deployment was not implemented because Docker was not installed in the testing environment.

However, recommended Docker security best practices were reviewed:

- Use minimal base images
- Scan container images for vulnerabilities

- Avoid running containers as root
- Keep images updated
- Restrict container permissions

11. Conclusion

Week 6 focused on advanced security auditing, compliance verification, and final penetration testing.

Multiple industry-standard tools including OWASP ZAP, Nikto, Lynis, npm Audit, and Metasploit were used to evaluate the security posture of OWASP Juice Shop.

The assessment confirmed that security improvements implemented during previous weeks significantly strengthened the application's defenses. Security controls such as password hashing, JWT authentication, rate limiting, CSP, HSTS, logging, and intrusion detection contributed to a more secure application environment.

Overall, the project successfully demonstrated practical web application security assessment, vulnerability analysis, and security hardening techniques.